

Reconnaissance Lab Handout

September 2, 2026

CONTENTS

Reconnaissance — Student Lab Handout	
PART 1 — What is reconnaissance? (read first)	
Two kinds of recon	
PART 2 — THE RULE (do not skip)	
PART 3 — Your assigned target	
Why every active target here is safe to scan	
NOT on the list — and why	
PART 4 — The tools: YOU fill this in (marked)	
PART 5 — Reading the output (decoder)	
whois — key fields	
theHarvester — what the output means	
dig — DNS record types	
nmap — output columns	
Common ports — what each open door means	
whatweb — key fields	
PART 6 — WORKSHEET (the main part of your submission — see Part 8)	
A. whois — run: whois DOMAIN	
B. DNS — run: dig DOMAIN A then dig DOMAIN MX then dig DOMAIN NS then dig DOMAIN TXT	
C. Certificate transparency — open https://crt.sh/?q=%25.DOMAIN in a browser	
D. nmap — run: nmap -sV -Pn TARGET	
E. whatweb — run: whatweb https://TARGET (if that errors, try whatweb http://TARGET)	
F. Wrap-up	
G. Research questions — answer in your own words, and cite the page/link you used	

PART 7 — If a tool isn't installed

PART 8 — Submission

How this is marked

Reconnaissance — Student Lab Handout

Duration: ~30 min in class + finish the report on your own afterwards **Deadline:** submit by _____ today (instructor fills in the time) **What you submit:** ONE document containing (a) the filled-in Part 4 table and (b) the completed Worksheet (Part 6, sections A–G) with your command outputs pasted in as evidence **Your target:** each student is assigned ONE row from Part 3 — you work only on that one **Spot check:** a few students, chosen at random, will be asked to open their submitted document and explain any answer in it

PART 1 — What is reconnaissance? (read first)

Reconnaissance (“recon”) is the first phase of a penetration test: **learn everything you can about a target before you touch it.**

The order of a pentest:

```

RECON → SCANNING → EXPLOITATION → POST-EXPLOITATION → REPORTING
(learn)  (find doors) (break in)      (go deeper)          (write up)

```

Recon output is **never the end** — it is the raw material for the next phase. Example chain you will see today:

```

nmap tells you:  22/tcp open  ssh  OpenSSH 6.6.1
you search:      "OpenSSH 6.6.1 exploit"
you find:        a known vulnerability (CVE)
that becomes:    your way in

```

TWO KINDS OF RECON

Type	Meaning	Does the target notice?	Tools today
Passive	You collect public information. You never send anything to the target.	No	whois, dig, crt.sh (theHarvester = optional)
Active	You send packets to the target and read the responses.	Yes — it can be logged	nmap, whatweb

Always know which kind you are running.

PART 2 — THE RULE (do not skip)

Only run active tools against systems you own or that explicitly permit testing.

Port-scanning or probing a system without permission is a criminal offence in most countries (in India, IT Act sections 43 and 66). “I was just learning” is not a defence.

Passive lookups (whois, DNS, crt.sh) are fine on any domain — they don’t touch the target.

Active scanning (nmap, whatweb) is **only** allowed on the approved targets below.

PART 3 — Your assigned target

Each student works ONE row of the table below. Your row number = your roll number. If your roll number is bigger than 16, keep subtracting 16 until you land between 1 and 16. (Example: roll 25 $\rightarrow 25 - 16 = 9$ $\rightarrow$ use row 9. Roll 40 $\rightarrow 40 - 16 - 16 = 8$ $\rightarrow$ row 8.) If you are unsure, ask the instructor for your row number.

You run **every** tool in the lab against **only** your assigned row — the active target with the active tools, the passive domain with the passive tools.

#	Active target — use with nmap, whatweb (ONLY these are authorised to scan)	Passive domain — use with whois, dig, crt.sh
1	scanme.nmap.org	nmap.org
2	testphp.vulnweb.com	wikipedia.org
3	testasp.vulnweb.com	mozilla.org
4	testaspnet.vulnweb.com	python.org
5	testhtml5.vulnweb.com	github.com
6	rest.vulnweb.com	kernel.org
7	ginandjuice.shop	apache.org
8	demo.testfire.net	debian.org
9	scanme.nmap.org	ietf.org
10	testphp.vulnweb.com	mit.edu
11	testasp.vulnweb.com	wordpress.org
12	testaspnet.vulnweb.com	gnu.org
13	testhtml5.vulnweb.com	archlinux.org
14	rest.vulnweb.com	postgresql.org
15	ginandjuice.shop	ruby-lang.org
16	demo.testfire.net	openbsd.org

WHY EVERY ACTIVE TARGET HERE IS SAFE TO SCAN

Target	Published by	For
<code>scanme.nmap.org</code>	The Nmap project	Scan practice — they explicitly permit it
<code>*.vulnweb.com</code> (testphp, testasp, testaspnet, testhtml5, rest)	Acunetix	Public test sites , built to be scanned
<code>ginandjuice.shop</code>	PortSwigger	Public deliberately-vulnerable shop for scanner/DAST testing
<code>demo.testfire.net</code>	IBM (“Altoro Mutual” demo bank)	Public demo vulnerable app for AppScan testing

The **passive domains** are only ever queried with passive tools (whois / DNS / crt.sh), which send **nothing** to the target — so any real domain is fine there.

Rows 9–16 reuse the same active targets as rows 1–8. If another student has the same active target as you, your `nmap` results should come out **identical** — check with them at the end; if they differ, one of you made a mistake.

NOT ON THE LIST — AND WHY

Looks tempting	Do NOT do this	Do this instead
OWASP Juice Shop public demo	Don't nmap/whatweb <code>demo.owasp-juice.shop</code> — it's a shared free resource	Host your own: <code>docker run --rm -p 3000:3000 bkimminich/juice-shop</code> , then scan <code>localhost:3000</code>
<code>hackthissite.org</code>	Don't port-scan their infrastructure	Do the missions in a browser only
HackTheBox / TryHackMe boxes	Don't scan from the open internet	Connect their VPN, scan only your assigned lab box
DVWA, bWAPP, WebGoat, Metasploitable	These have no public instance	Run them in a local VM / Docker

Never point nmap or whatweb at anything not in the “Active target” column — no real company, bank, government site, or a friend’s server. That is a criminal offence (Part 2).

PART 4 — The tools: YOU fill this in (marked)

Every tool answers **one question** about the target. If you can say the question, you understand the tool.

How to fill this in: watch the instructor’s demo, use the “what you get back” hint in each row, and check Part 5. There is no single correct wording — you are marked on whether the idea is right, not exact words. Write it yourself; do not copy another student’s phrasing.

Tool	The one question it answers about the target (you write)	What you get back (hint)	One attack the information sets up (you write)
whois		Registrar, creation/expiry dates, name servers, admin/abuse email	
dig		A record (IP), MX (mail provider), NS (DNS host), TXT/SPF	
crt.sh		Every subdomain that ever got a TLS certificate	
theHarvester		Employee emails, names, subdomains from public sources	
nmap (-sV)		Open ports + service name + version + OS guess	
whatweb		Web server + version, CMS + version, frameworks, JS libraries, WAF	

Hint for the “question” column: start each answer with “*What / Who / Which...*”. Hint for the “attack” column: name a specific attack (phishing, password spraying, subdomain takeover, exploit a known CVE, email spoofing, man-in-the-middle...).

PART 5 — Reading the output (decoder)

This is the part most people skip. **Every line of output is a fact about the target.**

WHOIS — KEY FIELDS

Field	What it tells you
Registrar	Which company sold the domain (GoDaddy, Namecheap...)
Creation Date	How old the domain is — old = more history, more forgotten assets
Registry Expiry Date	If it lapses, someone else can grab it
Name Server	Who runs their DNS (often Cloudflare, AWS, GoDaddy) — another provider in scope
Registrant Organization / Country	Often “Redacted for Privacy” now — note when it is <i>not</i> redacted
Admin Email / Abuse Email	A real, working email address and format
DNSSEC	unsigned = DNS responses can be more easily spoofed

THEHARVESTER — WHAT THE OUTPUT MEANS

Prints a list of **email addresses**, **host/subdomain names**, and sometimes IPs that it scraped from public search engines for the domain you gave it. The emails reveal the company’s address format (e.g. `first.last@company.com`); once you know the format you can guess every employee’s address for phishing or password-guessing. (Optional in this lab.)

DIG — DNS RECORD TYPES

Record	Meaning	Why an attacker cares
A	IPv4 address of a hostname	This is the IP you would scan
AAAA	IPv6 address	Sometimes less firewalled than IPv4
CNAME	Alias → another hostname	If it points to a service that no longer exists → subdomain takeover
MX	Mail servers (with priority number)	Reveals mail provider (Google Workspace, Microsoft 365) → phishing route
NS	Authoritative name servers	The DNS provider
TXT	Free text — includes SPF (<code>v=spf1 ...</code>), DMARC , and <code>...-site-verification</code> strings	SPF lists every service allowed to send mail as them → shows which SaaS they use; weak SPF → email spoofing
SOA	Zone admin info	Contact + zone serial number

Run (replace `DOMAIN` with your assigned passive domain from Part 3): `dig DOMAIN A` · `dig DOMAIN MX` · `dig DOMAIN NS` · `dig DOMAIN TXT` (`dig DOMAIN ANY` sometimes works too, but many big providers now refuse it — query each record type separately as above.)

NMAP — OUTPUT COLUMNS

```

PORT      STATE  SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))

```

Column	Meaning
PORT	Port number + protocol (22/tcp)
STATE	open = a service is actively accepting connections (this is the interesting one) · closed = reachable, nothing listening · filtered = a firewall is blocking, nmap can't tell
SERVICE	nmap's guess of what the service is
VERSION	Only shown with -sV — the product and version number. Write this down — it is what you search for exploits

COMMON PORTS — WHAT EACH OPEN DOOR MEANS

Port	Service	Attacker's interest
21	FTP	Anonymous login? Credentials sent in cleartext
22	SSH	Remote login — brute force, or exploit an old version
23	Telnet	Ancient, fully cleartext — should never be open
25	SMTP	Mail server — open relay checks
53	DNS	Try a zone transfer (AXFR)
80	HTTP	Website with no encryption
110 / 143	POP3 / IMAP	Mail retrieval — credential attacks
139 / 445	SMB (Windows file sharing)	Null sessions, EternalBlue on old Windows, share enumeration
443	HTTPS	Website with TLS — check the certificate and TLS version
3306	MySQL	Database exposed to the internet — weak/default creds
3389	RDP	Windows Remote Desktop — brute force, BlueKeep
8080	HTTP-alt	Proxies, dev servers, admin panels

WHATWEB — KEY FIELDS

Field	What it tells you
HTTPServer	Web server software + version (Apache/2.4.7)
X-Powered-By	Backend language/framework (PHP/5.6.40)
WordPress / Drupal / Joomla [x.x]	The CMS and its version → look up public exploits for that version
jQuery / Bootstrap [x.x]	Front-end library versions — old ones have known XSS issues
Title	The page title — hints at what the app is
Firewall / WAF entries	A web application firewall is present — payloads may need to evade it

PART 6 — WORKSHEET (the main part of your submission — see Part 8)

Name: _____ Roll no: _____ Date: _____ Row # from Part 3: _____ My active target (nmap, whatweb): _____ My passive domain (whois, dig, crt.sh): _____ Authorization: my active target is on the Part 3 approved list — a public test host published by its owner (Nmap / Acunetix / PortSwigger / IBM) for scanning practice.

Below, `TARGET` = your active target, `DOMAIN` = your passive domain.

A. WHOIS — RUN: `WHOIS DOMAIN`

1. Domain creation date: _____
2. Registrar: _____
3. Name servers (list them): _____
4. Any email address in the output: _____ (Most whois records hide the owner's details now and show only the registrar's `abuse@...` address — if so, write that one down.)
5. Why would an attacker want that email address / that piece of contact info? (1 sentence)

B. DNS — RUN: `DIG DOMAIN A` THEN `DIG DOMAIN MX` THEN `DIG DOMAIN NS` THEN `DIG DOMAIN TXT`

6. The `A` record (server IP): _____
 7. The `MX` records — which mail provider does this suggest? (write “self-hosted” if the MX names end in the same domain): _____
 8. Paste the `SPF` record (a `TXT` record starting `v=spf1`); if there is none, paste any other `TXT` record and say “no SPF”: _____
 9. **What does that record reveal about the services they use — or, if there is no SPF, why is that a problem for them?** (1 sentence)
-

C. CERTIFICATE TRANSPARENCY — OPEN `HTTPS://CRT.SH/?Q=%25.DOMAIN` IN A BROWSER

(The `%25.` at the front asks crt.sh for sub-domains specifically. If the page is very large or times out, wait and reload once, then just work with what loads.)

10. Roughly how many unique sub-domains are listed? (an estimate is fine — e.g. “fewer than 10”, “about 50”, “hundreds”): _____
 11. Write down up to 3 sub-domain names you see: _____
 12. **Which one looks the most interesting to attack, and why?** (1 sentence)
-

- **(Optional, not marked)** Run `theHarvester -d DOMAIN -b bing` and note any email addresses or hostnames it prints: _____

D. NMAP — RUN: `NMAP -SV -PN TARGET`

(`-Pn` tells nmap “don’t ping first, just scan” — several of the targets block ping and without `-Pn` nmap wrongly reports “Host seems down”. The scan takes 1–3 minutes; wait for it.)

13. List every port whose STATE is `open`. Add or remove rows as needed. If nmap shows no version for a service, write “unknown”. (Web-only targets may show just 80 and/or 443 — that is a normal, valid result.)

Port (e.g. 80/tcp)	Service	Version

14. Pick one service that shows a version number. Search the web for that exact version plus the word `exploit`, and again plus `CVE` (e.g. `Apache 2.4.7 CVE`). Write the CVE number / exploit name you found, or “none found”:

15. Of the open ports you listed, which one would you investigate first, and why? (2 sentences)

E. WHATWEB — RUN: `WHATWEB HTTPS://TARGET` (IF THAT ERRORS, TRY `WHATWEB HTTP://TARGET`)

16. Web server software + version (the `HTTPServer` field): _____

17. Any framework / CMS / JS library detected: _____

18. Is that web server version old? Search the web for `<web server name> latest version`, compare it to what you found, and say “current” or “outdated (latest is _____)”:

F. WRAP-UP

19. In 3 sentences: what did recon tell you about this target’s attack surface?

20. Paste all your raw command outputs below as evidence (or attach screenshots).

G. RESEARCH QUESTIONS — ANSWER IN YOUR OWN WORDS, AND CITE THE PAGE/LINK YOU USED

These are not in the tool output. You have to look them up and think.

21. **Passive vs active:** describe one real situation where a target *noticing* your active scan (getting logged / an alert firing) would ruin a real engagement.

22. **Pick one open port** from your nmap results. Research the service behind it:

- What is this service normally used for?
- Name **two** common ways attackers abuse it.

23. **CVE deep-dive:** take one service version you found and look up a CVE for it. (If your target genuinely has no known CVE, use `OpenSSH 6.6.1` from the Part 1 example instead.) Then answer:
- In one sentence, what does the vulnerability let an attacker do?
 - Does the attacker need valid credentials first (authenticated), or not (unauthenticated)?
 - Which is more dangerous, and why?
24. **Certificate transparency:** what is it, *why* does it exist, and why does it leak subdomains to anyone? (crt.sh is just a search front-end for it.)
25. **SPF records:** what is an SPF record for? If a domain publishes `v=spf1 -all`, what does that mean? If a domain has **no** SPF record at all, how does that help someone sending phishing email that looks like it came from that domain?
26. **Subdomain takeover:** explain what it is. Find one public bug-bounty write-up or blog post about a real subdomain takeover and summarise it in 3 sentences (paste the link).
27. **Why passive first?** give two concrete reasons a pentester does passive recon before touching the target with active tools.
28. **The law:** find your country's law on unauthorised access to a computer system. Write the act name, the section number, and the maximum penalty.
-

PART 7 — If a tool isn't installed

On Kali Linux all of these are already installed. On plain Ubuntu/Debian:

```
sudo apt update
sudo apt install -y whois dnsutils nmap whatweb theharvester
```

- `dnsutils` is the package that provides the `dig` command.
 - On **Windows**: use a Kali or Ubuntu VM, or WSL (`wsl --install`). `whois` and `dig` on Windows behave differently — do this lab from Linux.
 - `crt.sh` needs nothing installed — it is just a website.
 - If `theHarvester` is missing and you can't install it, skip the optional step in section C.
-

PART 8 — Submission

Put all of this in **one document** and submit it by the deadline on page 1:

- The **Part 4 table**, both blank columns filled in your own words.
- Worksheet sections **A–E**: every answer, plus your raw command outputs pasted into question 20.
- Worksheet section **F** (question 19): the 3-sentence attack-surface summary.
- Worksheet section **G** (questions 21–28): answered in your own words, each with the link or page you used.

Be ready to open the document and explain any answer if you are picked for the spot check.

HOW THIS IS MARKED

What	Which questions	Checks	Weight
Part 4 table filled in	Part 4	You understand what each tool is <i>for</i>	15%
Commands actually run	outputs pasted in Q20	You ran the tools on your assigned target	20%
Analysis answers	5, 9, 12, 15, 18	You can read and interpret the output	25%
CVE / version search	14	You can turn a version string into a known vulnerability	5%
Research questions	21–28	You looked things up and understood them	25%
Attack-surface summary	19	You can summarise a target in a few sentences	10%

Answers copied from another student, with no understanding shown in the spot check, score zero.

The most important thing to take away: an output line → a search → an exploit. That is how “just looking around” becomes an attack.